Technischer Schwachstellenbericht zur Identitätsplattform

Fiktives Amt für digitale Dienste | Prüfbericht | FIK-0024/2026

Synthetisches Beispieldokument – fiktive Sachverhalte. Stand: 15. Oktober 2026.

1. Prüfauftrag

Untersucht wurde eine nicht öffentlich erreichbare Testumgebung einer zentralen Identitätsplattform. Der Bericht unterscheidet reproduzierbare Beobachtungen von hypothetischen Angriffspfaden. Der Abschnitt dokumentiert den derzeitigen Kenntnisstand; Änderungen oder Ergänzungen werden in der folgenden Bearbeitung nachvollziehbar festgehalten.

Die Systemlandschaft ähnelt produktiven Komponenten, ist aber technisch getrennt. Für die Einordnung ist zu beachten, ob die Angaben als einzelne Beobachtungen, als zusammengefasste Informationen oder als Aussagen über konkrete Personen beziehungsweise Systeme verstanden werden. Die zuständige Stelle darf unbelegte Annahmen nicht als bereits bestätigte Erkenntnisse behandeln.

Der Auftraggeber prüft die Übertragbarkeit auf den Produktivbetrieb. Vor einer Weitergabe soll geprüft werden, ob alle Empfänger den notwendigen Kontext kennen und ob die im Text enthaltenen Informationen für den angegebenen Zweck benötigt werden. Wo Quellen fehlen, wird der Befund als offen statt als feststehend markiert.

Für die nächste Bearbeitungsrunde wurde vereinbart, den Sachverhalt anhand der vorhandenen Akten zu überprüfen. Ein isolierter Auszug aus diesem Abschnitt könnte die Aussage verändern, insbesondere wenn die dazugehörigen Einschränkungen entfallen. Die Dokumentation dient deshalb sowohl dem operativen Vorgehen als auch der späteren Nachvollziehbarkeit.

2. Systemübersicht

Die Plattform verwendet einen zentralen Authentifizierungsdienst und mehrere Anwendungsadapter. Die Dokumentation führt Rollen, Schnittstellentypen und Abhängigkeiten auf, jedoch keine Passwörter. Der Abschnitt dokumentiert den derzeitigen Kenntnisstand; Änderungen oder Ergänzungen werden in der folgenden Bearbeitung nachvollziehbar festgehalten.

Die blosse Erwähnung von Authentifizierungsverfahren erlaubt keine rechtliche Einstufung. Für die Einordnung ist zu beachten, ob die Angaben als einzelne Beobachtungen, als zusammengefasste Informationen oder als Aussagen über konkrete Personen beziehungsweise Systeme verstanden werden. Die zuständige Stelle darf unbelegte Annahmen nicht als bereits bestätigte Erkenntnisse behandeln.

Die Fachstelle vergleicht die Auswertung mit dem geltenden Katalog. Vor einer Weitergabe soll geprüft werden, ob alle Empfänger den notwendigen Kontext kennen und ob die im Text enthaltenen Informationen für den angegebenen Zweck benötigt werden. Wo Quellen fehlen, wird der Befund als offen statt als feststehend markiert.

Für die nächste Bearbeitungsrunde wurde vereinbart, den Sachverhalt anhand der vorhandenen Akten zu überprüfen. Ein isolierter Auszug aus diesem Abschnitt könnte die Aussage verändern, insbesondere wenn die dazugehörigen Einschränkungen entfallen. Die Dokumentation dient deshalb sowohl dem operativen Vorgehen als auch der späteren Nachvollziehbarkeit.

3. Beobachtete Schwachstelle

In einer Testkonfiguration war eine zusätzliche Berechtigungsprüfung in einem administrativen Ablauf deaktiviert. Eine Wiederholung im Testsystem zeigte eine unbeabsichtigte Einsicht in Konfigurationsmetadaten. Der Abschnitt dokumentiert den derzeitigen Kenntnisstand; Änderungen oder Ergänzungen werden in der folgenden Bearbeitung nachvollziehbar festgehalten.

Der Bericht gibt bewusst keine ausführbaren Angriffsschritte oder geheimen Zugangsdaten wieder. Für die Einordnung ist zu beachten, ob die Angaben als einzelne Beobachtungen, als zusammengefasste Informationen oder als Aussagen über konkrete Personen beziehungsweise Systeme verstanden werden. Die zuständige Stelle darf unbelegte Annahmen nicht als bereits bestätigte Erkenntnisse behandeln.

Die Entwickler korrigieren die Prüfreihenfolge vor dem nächsten Release. Vor einer Weitergabe soll geprüft werden, ob alle Empfänger den notwendigen Kontext kennen und ob die im Text enthaltenen Informationen für den angegebenen Zweck benötigt werden. Wo Quellen fehlen, wird der Befund als offen statt als feststehend markiert.

Für die nächste Bearbeitungsrunde wurde vereinbart, den Sachverhalt anhand der vorhandenen Akten zu überprüfen. Ein isolierter Auszug aus diesem Abschnitt könnte die Aussage verändern, insbesondere wenn die dazugehörigen Einschränkungen entfallen. Die Dokumentation dient deshalb sowohl dem operativen Vorgehen als auch der späteren Nachvollziehbarkeit.

4. Mögliche Folgen

Bei gleicher Konfiguration im Produktivsystem könnte ein unberechtigter Zugriff auf technische Betriebsinformationen möglich sein. Ob diese Annahme zutrifft, ist derzeit nicht bestätigt. Der Abschnitt dokumentiert den derzeitigen Kenntnisstand; Änderungen oder Ergänzungen werden in der folgenden Bearbeitung nachvollziehbar festgehalten.

Ohne diese Information lässt sich das tatsächliche Schadensausmass nicht zuverlässig beurteilen. Für die Einordnung ist zu beachten, ob die Angaben als einzelne Beobachtungen, als zusammengefasste Informationen oder als Aussagen über konkrete Personen beziehungsweise Systeme verstanden werden. Die zuständige Stelle darf unbelegte Annahmen nicht als bereits bestätigte Erkenntnisse behandeln.

Eine separate technische Risikobeurteilung ist angeordnet. Vor einer Weitergabe soll geprüft werden, ob alle Empfänger den notwendigen Kontext kennen und ob die im Text enthaltenen Informationen für den angegebenen Zweck benötigt werden. Wo Quellen fehlen, wird der Befund als offen statt als feststehend markiert.

Für die nächste Bearbeitungsrunde wurde vereinbart, den Sachverhalt anhand der vorhandenen Akten zu überprüfen. Ein isolierter Auszug aus diesem Abschnitt könnte die Aussage verändern, insbesondere wenn die dazugehörigen Einschränkungen entfallen. Die Dokumentation dient deshalb sowohl dem operativen Vorgehen als auch der späteren Nachvollziehbarkeit.

5. Gegenmassnahmen

Das Team führte eine zusätzliche serverseitige Prüfung ein und ergänzte Regressionstests. Der erste Nachtest bestätigte die Korrektur in der Laborumgebung. Der Abschnitt dokumentiert den derzeitigen Kenntnisstand; Änderungen oder Ergänzungen werden in der folgenden Bearbeitung nachvollziehbar festgehalten.

Ein erfolgreicher Test ersetzt noch nicht die formelle Freigabe für den Produktivbetrieb. Für die Einordnung ist zu beachten, ob die Angaben als einzelne Beobachtungen, als zusammengefasste Informationen oder als Aussagen über konkrete Personen beziehungsweise Systeme verstanden werden. Die zuständige Stelle darf unbelegte Annahmen nicht als bereits bestätigte Erkenntnisse behandeln.

Der Betrieb plant eine kontrollierte Einführung. Vor einer Weitergabe soll geprüft werden, ob alle Empfänger den notwendigen Kontext kennen und ob die im Text enthaltenen Informationen für den angegebenen Zweck benötigt werden. Wo Quellen fehlen, wird der Befund als offen statt als feststehend markiert.

Für die nächste Bearbeitungsrunde wurde vereinbart, den Sachverhalt anhand der vorhandenen Akten zu überprüfen. Ein isolierter Auszug aus diesem Abschnitt könnte die Aussage verändern, insbesondere wenn die dazugehörigen Einschränkungen entfallen. Die Dokumentation dient deshalb sowohl dem operativen Vorgehen als auch der späteren Nachvollziehbarkeit.

6. Beteiligte Stellen

Der Prüfbericht wurde von zwei fiktiven Prüfern erstellt und an die Systemverantwortung übermittelt. Enthalten sind dienstliche Namen, Rollen und E-Mail-Adressen. Der Abschnitt dokumentiert den derzeitigen Kenntnisstand; Änderungen oder Ergänzungen werden in der folgenden Bearbeitung nachvollziehbar festgehalten.

Die personenbezogenen Kontaktdaten sind von der technischen Schutzbedürftigkeit zu unterscheiden. Für die Einordnung ist zu beachten, ob die Angaben als einzelne Beobachtungen, als zusammengefasste Informationen oder als Aussagen über konkrete Personen beziehungsweise Systeme verstanden werden. Die zuständige Stelle darf unbelegte Annahmen nicht als bereits bestätigte Erkenntnisse behandeln.

Die Empfängerliste wird vor jeder weiteren Weitergabe kontrolliert. Vor einer Weitergabe soll geprüft werden, ob alle Empfänger den notwendigen Kontext kennen und ob die im Text enthaltenen Informationen für den angegebenen Zweck benötigt werden. Wo Quellen fehlen, wird der Befund als offen statt als feststehend markiert.

Für die nächste Bearbeitungsrunde wurde vereinbart, den Sachverhalt anhand der vorhandenen Akten zu überprüfen. Ein isolierter Auszug aus diesem Abschnitt könnte die Aussage verändern, insbesondere wenn die dazugehörigen Einschränkungen entfallen. Die Dokumentation dient deshalb sowohl dem operativen Vorgehen als auch der späteren Nachvollziehbarkeit.

7. Einordnung

Der Bericht trägt den Bearbeitungsvermerk «Prüfstand – noch nicht freigegeben». Dieser Vermerk ist keine rechtsverbindliche Einstufung nach ISV. Der Abschnitt dokumentiert den derzeitigen Kenntnisstand; Änderungen oder Ergänzungen werden in der folgenden Bearbeitung nachvollziehbar festgehalten.

Ein Modell darf aus Schlagworten wie kritisch oder vertraulich nicht direkt eine Stufe ableiten. Für die Einordnung ist zu beachten, ob die Angaben als einzelne Beobachtungen, als zusammengefasste Informationen oder als Aussagen über konkrete Personen beziehungsweise Systeme verstanden werden. Die zuständige Stelle darf unbelegte Annahmen nicht als bereits bestätigte Erkenntnisse behandeln.

Die Entscheidung wird unter Kenntnis der tatsächlichen Offenlegungsfolgen gefällt. Vor einer Weitergabe soll geprüft werden, ob alle Empfänger den notwendigen Kontext kennen und ob die im Text enthaltenen Informationen für den angegebenen Zweck benötigt werden. Wo Quellen fehlen, wird der Befund als offen statt als feststehend markiert.

Für die nächste Bearbeitungsrunde wurde vereinbart, den Sachverhalt anhand der vorhandenen Akten zu überprüfen. Ein isolierter Auszug aus diesem Abschnitt könnte die Aussage verändern, insbesondere wenn die dazugehörigen Einschränkungen entfallen. Die Dokumentation dient deshalb sowohl dem operativen Vorgehen als auch der späteren Nachvollziehbarkeit.

8. Abschluss und Nachkontrolle

Die Nachkontrolle soll nach Übernahme der Korrekturen erfolgen. Ein offener Punkt betrifft die Abgrenzung von Test- und Produktivkonfiguration. Der Abschnitt dokumentiert den derzeitigen Kenntnisstand; Änderungen oder Ergänzungen werden in der folgenden Bearbeitung nachvollziehbar festgehalten.

Der endgültige Prüfstatus ist zum Berichtsdatum noch offen. Für die Einordnung ist zu beachten, ob die Angaben als einzelne Beobachtungen, als zusammengefasste Informationen oder als Aussagen über konkrete Personen beziehungsweise Systeme verstanden werden. Die zuständige Stelle darf unbelegte Annahmen nicht als bereits bestätigte Erkenntnisse behandeln.

Die fachliche Stelle ergänzt den Bericht nach Abschluss der Nachtests. Vor einer Weitergabe soll geprüft werden, ob alle Empfänger den notwendigen Kontext kennen und ob die im Text enthaltenen Informationen für den angegebenen Zweck benötigt werden. Wo Quellen fehlen, wird der Befund als offen statt als feststehend markiert.

Für die nächste Bearbeitungsrunde wurde vereinbart, den Sachverhalt anhand der vorhandenen Akten zu überprüfen. Ein isolierter Auszug aus diesem Abschnitt könnte die Aussage verändern, insbesondere wenn die dazugehörigen Einschränkungen entfallen. Die Dokumentation dient deshalb sowohl dem operativen Vorgehen als auch der späteren Nachvollziehbarkeit.

9. Zuständigkeiten und Aktenführung

Die sachbearbeitende Stelle führt die in diesem Dokument genannten Angaben in einem abgegrenzten Geschäftsdossier. Fachliche Rückfragen werden nicht informell entschieden, sondern anhand der dokumentierten Zuständigkeiten geklärt. Änderungen am Sachverhalt werden mit Datum und Bearbeitungsgrund versehen.

Die Aktenführung soll sicherstellen, dass spätere Leser zwischen Ausgangsinformationen, Abklärungen und Bewertungen unterscheiden können. Eine Weitergabe ohne den zugehörigen Kontext könnte zu falschen Schlussfolgerungen führen.

Auf eine pauschale Interpretation einzelner Signalwörter wird bewusst verzichtet. Die Unterlagen müssen im Zusammenhang mit ihrem Erstellungszweck, dem Empfängerkreis und den belegten Umständen betrachtet werden.

Die ausstehenden Rückfragen werden in der nächsten Bearbeitungsrunde gesammelt. Entscheide und ihre Begründung werden getrennt von den zugrunde liegenden Beobachtungen dokumentiert.

10. Qualitätssicherung und offene Fragen

Für die abschliessende Qualitätsprüfung werden die noch offenen Sachverhalte gesondert aufgeführt. Bestehende Angaben gelten nur für den beschriebenen Bearbeitungsstand und sind nicht ohne Weiteres auf andere Dienststellen oder Verfahren übertragbar.

In der internen Rückmeldung wurde darauf hingewiesen, dass vereinfachte Zusammenfassungen wichtige Einschränkungen verlieren können. Die verantwortliche Stelle prüft deshalb, ob im Ergebnis alle relevanten

Vorbehalte, Datenquellen und zeitlichen Grenzen sichtbar bleiben.

Auf eine pauschale Interpretation einzelner Signalwörter wird bewusst verzichtet. Die Unterlagen müssen im Zusammenhang mit ihrem Erstellungszweck, dem Empfängerkreis und den belegten Umständen betrachtet werden.

Die ausstehenden Rückfragen werden in der nächsten Bearbeitungsrunde gesammelt. Entscheide und ihre Begründung werden getrennt von den zugrunde liegenden Beobachtungen dokumentiert.